

ОПРЕДЕЛЕНИЕ УГРОЗ БЕЗОПАСНОСТИ ПЕРСОНАЛЬНЫХ ДАННЫХ

4_Модель_угроз_и_акт_УЗ.md

и АКТ ОПРЕДЕЛЕНИЯ УРОВНЯ ЗАЩИЩЁННОСТИ

Утверждено: «» _ 2026 г. **Основание:** пункт 1 части 2 статьи 19 Федерального закона от 27.07.2006 № 152-ФЗ; постановление Правительства РФ от 01.11.2012 № 1119; методический документ ФСТЭК России по определению угроз безопасности информации.

Требуется сверки. Определение уровня защищённости в разделе 7 сделано по логике постановления Правительства РФ № 1119, но **текст постановления при подготовке не сверялся построчно**. До утверждения акта сверить пункты о критериях уровней защищённости с действующей редакцией. Ошибка в уровне на одну ступень означает разницу между необязательностью и обязательностью сертифицированных средств защиты информации.

ЧАСТЬ I. ОПРЕДЕЛЕНИЕ УГРОЗ

1. Описание информационной системы

Наименование: информационная система персональных данных сервиса маскирования персональных данных в документах.

Назначение: автоматизированное выявление и маскирование (псевдонимизация) персональных данных в документах, передаваемых заказчиками, с формированием таблицы соответствий.

Состав:

Компонент	Описание	Размещение
Веб-интерфейс	Next.js, серверные маршруты /api/anonymize, /api/deanonymize — работают как серверный прокси	Инфраструктура ООО «ИНТЕРФОНИКА», РФ
Сервер обработки	Python, http.server.ThreadingHTTPServer, слушает 127.0.0.1:8010 за nginx	Там же
Инференс-эндпоинт LLM	oui.interfonica.cloud/v1, модель Qwen 3.5 35B	ООО «ИНТЕРФОНИКА», территория подлежит подтверждению
Инференс-эндпоинт GLiNER	oui.interfonica.cloud/gliner	Там же
Журналы	logs/usage.jsonl (потребление), logs/depersonalization.jsonl (учёт операций)	Файловая система сервера

Хранилище: постоянное хранилище персональных данных отсутствует. Задания, результаты и таблицы соответствий размещаются в оперативной памяти процесса и удаляются по истечении установленного срока жизни (600 секунд) либо после выдачи.

Границы контролируемой зоны: центр обработки данных ООО «ИНТЕРФОНИКА». За пределы контролируемой зоны данные передаются на инференс-эндпоинты, принадлежащие тому же лицу.

2. Обрабатываемые персональные данные

Иные категории персональных данных (не специальные, не биометрические, не общедоступные): фамилия, имя, отчество; должность; сведения о документах, удостоверяющих личность; страховой номер индивидуального лицевого счёта; идентификационный номер налогоплательщика; адрес; контактные данные; банковские реквизиты.

Субъекты — **лица, не являющиеся работниками оператора**. Ориентировочное количество — **менее 100 000**.

Специальные категории и биометрические персональные данные не обрабатываются; их передача запрещена договором.

3. Модель нарушителя

Тип	Потенциал	Мотивация
Внешний нарушитель из сети «Интернет»	Базовый	Получение персональных данных для последующего использования
Недобросовестный пользователь сервиса	Базовый	Доступ к результатам обработки других пользователей
Работник привлечённого лица (провайдер, оператор шлюза)	Базовый повышенный	Любопытство, корыстный интерес
Разработчик, имеющий доступ к среде	Базовый повышенный	Ошибка либо злоупотребление

Нарушители с высоким потенциалом (специальные службы, обладающие возможностью внедрения недекларированных возможностей на этапе разработки системного и прикладного программного обеспечения) признаются **неактуальными**: система не относится к государственным информационным системам, не обрабатывает сведения, составляющие государственную тайну, и не входит в состав значимых объектов критической информационной инфраструктуры.

4. Актуальные угрозы

№	Угроза	Обоснование актуальности	Меры нейтрализации
У-1	Несанкционированный доступ к серверу обработки из сети	Отсутствует аутентификация входящих запросов	Аутентификация каждого запроса; ограничение доступа средствами nginx; привязка к 127.0.0.1

№	Угроза	Обоснование актуальности	Меры нейтрализации
У-2	Доступ к результату обработки другого пользователя	Идентификатор задания не привязан к субъекту доступа	Привязка <code>job_id</code> к аутентифицированному субъекту; криптостойкий идентификатор
У-3	Перехват или раскрытие таблицы соответствий	Ключ деанонимизации передаётся в одном ответе с результатом	Раздельная выдача документа и ключа; режим без формирования ключа; исключение <code>spans[].text</code> из ответа
У-4	Утечка через дампы памяти процесса	В дампе оказываются исходный текст и таблица соответствий	Запрет сброса <code>core dump</code> (реализовано); отдельный системный пользователь; запрет отладки процесса
У-5	Утечка через файл подкачки	Страницы памяти с персональными данными могут попасть в <code>swap</code>	Отключение <code>swap</code> либо шифрование раздела подкачки
У-6	Компрометация канала до инференс-эндпоинта	Передаётся сырой текст до маскирования	TLS; при необходимости — сертифицированные средства криптографической защиты; предварительное маскирование детерминированными детекторами до обращения к модели
У-7	Раскрытие данных на стороне привлечённого лица	Оператор шлюза обрабатывает содержимое документов	Договор поручения; запрет логирования содержимого и использования для обучения; право проверки
У-8	Компрометация аутентификационных данных	Реализовавшийся инцидент: токен доступа находился в исходном коде	Хранение секретов только в окружении; ротация; автоматическая проверка кода на наличие секретов
У-9	Несанкционированный доступ к журналам	<code>logs/usage.jsonl</code> содержит имена файлов, способные включать персональные данные	Замена имени файла хешем; права доступа 0600; отдельный пользователь
У-10	Отказ в обслуживании; загрузка вредоносных документов	Приём произвольных файлов от пользователей	Ограничение объёма (50 МБ); ограничение частоты запросов; проверка типов; защита от архивных бомб

5. Угрозы, признанные неактуальными

Угроза	Обоснование
Утечка из системы управления базами данных	Персистентное хранилище персональных данных отсутствует

Угроза	Обоснование
Утечка из резервных копий	Резервное копирование персональных данных не производится
Угрозы, связанные с недекларированными возможностями системного и прикладного программного обеспечения	Нарушитель с соответствующим потенциалом признан неактуальным, раздел 3
Угрозы среды виртуализации	Средства виртуализации оператором не администрируются; относятся к зоне ответственности провайдера
Угрозы каналов побочных электромагнитных излучений и наводок	Обработка ведётся в аттестованном центре обработки данных провайдера

6. Остаточные риски, принимаемые оператором

Риск	Причина невозможности полного устранения
Неполное затирание значений в оперативной памяти	В интерпретаторе CPython строки неизменяемы и копируются сборщиком мусора; гарантированное затирание средствами языка недостижимо. Компенсируется мерами У-4, У-5
Пропуск отдельных персональных данных детектором (ложноотрицательные срабатывания)	Свойство методов машинного обучения. Компенсируется измерением полноты и обязательной проверкой результата заказчиком, закреплённой договором
Зависимость от добросовестности привлечённого лица	Компенсируется договором поручения и правом проверки

ЧАСТЬ II. АКТ ОПРЕДЕЛЕНИЯ УРОВНЯ ЗАЩИЩЁННОСТИ

7. Исходные данные и вывод

Показатель	Значение	Обоснование
Категория обрабатываемых персональных данных	Иные категории	Специальные категории и биометрические данные не обрабатываются, их передача запрещена договором
Отношение субъектов к оператору	Не являются работниками оператора	Субъекты — лица, упомянутые в документах заказчиков

Показатель	Значение	Обоснование
Количество субъектов	Менее 100 000	Оценка на основании планируемого объёма
Тип актуальных угроз	3-й тип — угрозы, не связанные с наличием недеklarированных возможностей в системном и прикладном программном обеспечении	Раздел 3: нарушитель с соответствующим потенциалом признан неактуальным

ВЫВОД: требуется обеспечение 4-го уровня защищённости персональных данных (УЗ-4).
[ПРОВЕРИТЬ по тексту ПП РФ № 1119]

Что следует из УЗ-4

Согласно приказу ФСТЭК России от 18.02.2013 № 21, для 3-го и 4-го уровней защищённости допускается применение средств защиты информации, прошедших оценку соответствия в форме, определяемой оператором, — обязательная сертификация не требуется. Это существенно снижает затраты.

Условия, при которых уровень повышается

Условие	Новый уровень	Последствие
Начинается обработка специальных категорий (статья 10)	Повышается	Обязательны сертифицированные средства защиты информации
Число субъектов превышает 100 000	Повышается	Расширяется состав обязательных мер
Угрозы 2-го типа признаются актуальными	Повышается	Обязательны сертифицированные средства защиты

Договорный запрет на передачу специальных категорий персональных данных — не формальность, а условие сохранения УЗ-4. Его исключение из договора влечёт пересмотр настоящего акта и кратный рост затрат на защиту.

8. Оценка эффективности принимаемых мер

Пункт 4 части 2 статьи 19 требует проведения оценки эффективности до ввода информационной системы в эксплуатацию. Оценка проводится оператором самостоятельно; результаты оформляются отдельным актом.

До завершения задач У-1, У-2, У-8 и У-9 положительная оценка эффективности дана быть не может.

9. Подписи

Определение угроз и уровень защищённости определил:

___ / ___ / «_» ____ 2026 г.